

20EIE554T – CYBERSECURITY IN INDUSTRIAL AUTOMATION

Dr.G.Y.Rajaa Vikhram
Assistant Professor/EIE
SRMIST

Course Learning Rationale (CLR):	The purpose of learning this course is to:
CLR-1 :	<i>Introduce the basic knowledge in industrial automation and control systems</i>
CLR-2 :	<i>Know the basic concepts of information system security for industrial control systems</i>
CLR-3 :	<i>Understand the difference between IACS and IT paradigms</i>
CLR-4 :	<i>Impart the adequate information about risk management for IACS</i>
CLR-5 :	<i>Introduce the security methodologies and approaches for IACS</i>
CLR-6 :	<i>Understand the need of cybersecurity for different industrial applications</i>

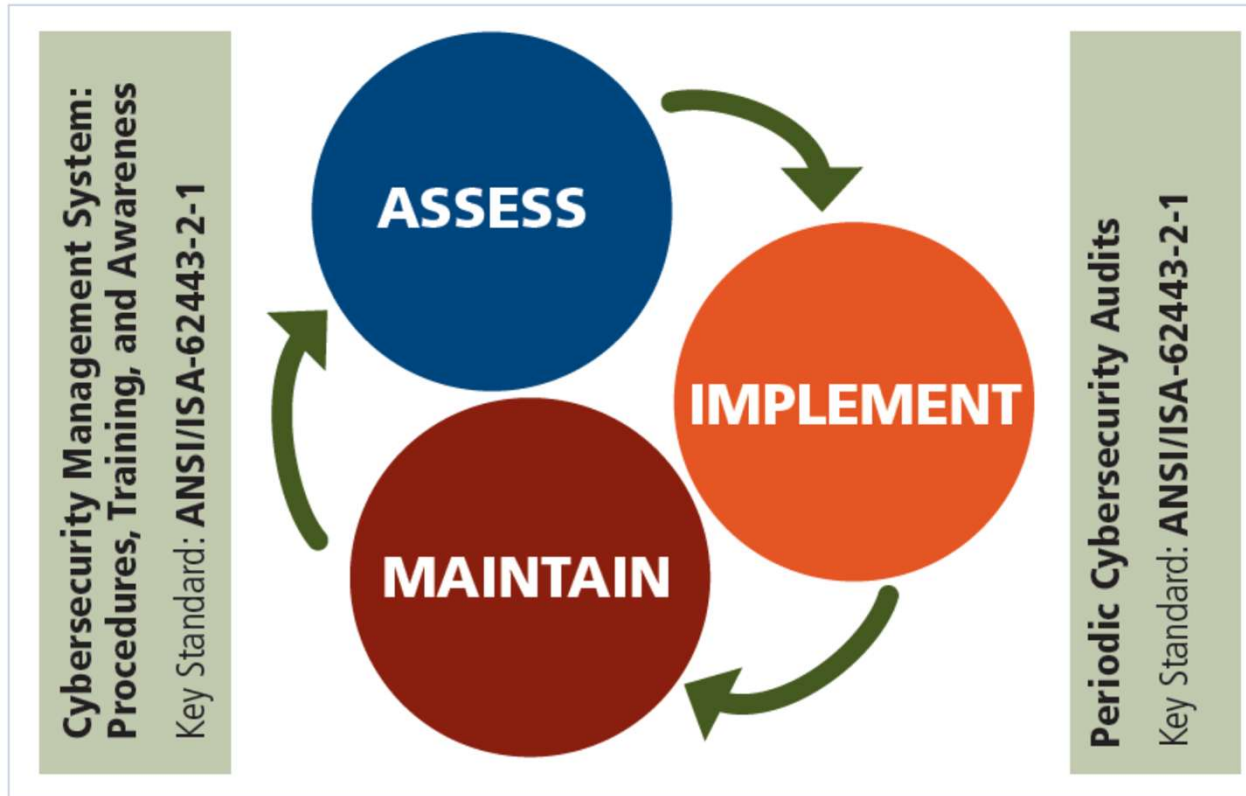
Course Outcomes (CO):	At the end of this course, learners will be able to:
CO-1 :	Describe the basic concepts of industrial automation and control systems
CO-2 :	Illustrate any application with add-on security features in industrial control systems
CO-3 :	Select the software with IT paradigms for IACS
CO-4 :	Analyze the risk management approach for IACS
CO-5 :	Examine the security methodologies for industrial systems
CO-6 :	Design cybersecurity resilient algorithm for selective applications

Cyber security Design and Implementation
12
Cyber security lifecycle
Conceptual design process
Detailed design process
Firewall design
Remote access design
Intrusion detection design
Tutorial: 1 – Cybersecurity algorithm
Security Standards, Guidelines NIST – Guide to ICS Security, Management Controls
Operational Controls, Technical Controls
ANSI/ISA security technologies, Blocking Access Control

Encryption Technologies, Physical Security Controls
Personal Security Controls,
Tutorial: 2 – Cybersecurity design
NERC – Critical Infrastructure Protection
Critical Cyber Asset Identification
Security Management Controls
Personal and Training
Electronic Security
Physical Security of Critical Cyber Assets
<i>Recovery Plans</i>
Tutorial: 3 – Smart grid simulation

Chapter 4 presented important risk management methodologies and their application to industrial automation and control systems. *Chapter 5* will build on the results of risk management and develop in detail the foundation of security controls that are proven, effective, and applicable to industrial automation and control systems.

IACS Security Lifecycle: An Overview



Automation and Control System Security Standards and Guidelines

The fundamental principles for protecting computer systems and networks are valid across all application domains. However, these principles have to be tailored to the world of industrial automation and control systems to be effective in protecting these systems. From experience and application of engineering approaches, a number of standards and guidelines have been developed and documented for securing automation and control systems. These materials take in to account the characteristics of industrial automation and control systems and present measures that should be taken to protect these systems.

Some of the important documents that address automation and control system security are:

- NIST Special Publication 800-82, *Guide to Industrial Control Systems (ICS) Security*

- ANSI/ISA-TR99.00.01-2007, *Security Technologies for Industrial Automation and Control Systems*
- North American Electric Reliability Corporation (NERC), *Critical Infrastructure Protection (CIP) Cybersecurity Standards*
- NIST Special Publication 800-53, *Recommended Security Controls for Federal Information Systems*
- Department of Homeland Security, *Catalog of Control Systems Security: Recommendations for Standards Developers*
- AMI-SEC Task Force, *AMI System Security Requirements*
- DOD Instruction 8500.2, *Information Assurance (IA) Implementation*

This list is not meant to be all-inclusive, but it comprises some of the major standards and guidelines addressing industrial automation and control system security and, among them, covers the major protection approaches to securing these systems. These standards and guidelines will be explored in this chapter. Following this exposition, the controls described will be cross-correlated in a table to provide a concise summary of these protection mechanisms with references back to the authoritative document.

NIST Special Publication 800-82, *Guide to Industrial Control Systems Security*

NIST SP 800-82¹ defines the major objectives for an industrial control system (ICS) security implementation as the following:

- **Restricting logical access to the ICS network and network activity.** This includes using a demilitarized zone (DMZ) network architecture with firewalls to prevent network traffic from passing directly between the corporate and ICS networks, and having separate authentication mechanisms and credentials for users of the corporate and ICS networks. The ICS should also use a network topology that has multiple layers, with the most critical communications occurring in the most secure and reliable layer.

- **Restricting physical access to the ICS network and devices.** Unauthorized physical access to components could cause serious disruption of the ICS's functionality. A combination of physical access controls should be used, such as locks, card readers, and/or guards.
- **Protecting individual ICS components from exploitation.** This includes deploying security patches in as expeditious a manner as possible, after testing them under field conditions; disabling all unused ports and services; restricting ICS user privileges to only those that are required for each person's role; tracking and monitoring audit trails; and using security controls, such as antivirus software and file integrity checking software, where technically feasible to prevent, deter, detect, and mitigate malware.

- **Maintaining functionality during adverse conditions.** This consists of designing the ICS so that each critical component has a redundant counterpart. Additionally, if a component fails, it should fail in a manner that does not generate unnecessary traffic on the ICS or other networks, and does not cause another problem elsewhere, such as a cascading event.
- **Restoring system after an incident.** Incidents are inevitable and an incident response plan is essential. A major characteristic of a good security program is how quickly a system can be restored after an incident has occurred.

NIST SP 800-82 categorizes recommended security controls into management controls, operational controls, and technical controls.

Management Controls

Management controls consist of risk assessment, planning, system and services acquisition, certification, accreditation, and security assessments.

Risk assessment is defined in NIST SP 800-82 as “the process of identifying risks to operations, assets, or individuals by determining the probability of occurrence, the resulting impact, and additional security controls that would mitigate this impact.” NIST SP 800-39, *Managing Information Security*

Risk, and NIST SP 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems*, provide guidance in the application of risk assessment, as discussed in [Chapter 5](#).

The remaining management controls are summarized as follows:

- **Planning** is the generation of a plan to determine and implement security controls, perform assessments, conduct incident response, and assign security levels. Continuous security evaluations and upgrades should be provided for through the security life cycle, keeping in mind the characteristics of industrial automation and control systems. The security life cycle integrates information security into the system development life cycle.
- **System and services acquisition** is the process of generating risk assessment-based acquisition policies and providing resources that address automation and control system security through the system development life cycle, including external suppliers. The systems life cycle comprises (i) initiation, (ii) development/acquisition, (iii) implementation, (iv) operation/maintenance, and (v) disposal.

- **Certification, accreditation, and security assessments** have the goals of ensuring that the specified controls are properly implemented and functioning as desired. A senior organizational official is responsible for accepting residual risk, and all security controls should be regularly monitored. Certification and accreditation are required for government agencies and Department of Defense entities, but equivalent evaluations can be performed for industrial automation and control systems.

Operational Controls

Operational controls are those controls that are performed by personnel as opposed to computer systems. NIST 800-82 defines these controls as follows:

- **Personnel Security (PS):** policies and procedures for personnel position categorization, screening, transfer, penalty, and termination; also addresses third-party personnel security

- **Physical and Environmental Protection (PE):** policies and procedures addressing physical, transmission, and display access control as well as environmental controls for conditioning (e.g., temperature, humidity) and emergency provisions (e.g., shutdown, power, lighting, fire protection)
- **Contingency Planning (CP):** policies and procedures designed to maintain or restore business operations, including computer operations (possibly at an alternate location) in the event of emergencies, system failures, or disaster
- **Configuration Management (CM):** policies and procedures for controlling modifications to hardware, firmware, software, and documentation to ensure that the automation and control system is protected against improper modifications prior to, during, and after system implementation

- **Maintenance (MA):** policies and procedures to manage all maintenance aspects of an automation and control system
- **System and Information Integrity (SI):** policies and procedures to protect information systems and their data from design flaws and data modification, using functionality verification, data integrity checking, intrusion detection, malicious code detection, and security alert and advisory controls
- **Media Protection (MP):** policies and procedures to ensure secure handling of media. Controls cover access, labeling, storage, transport, sanitization, destruction, and disposal
- **Incident Response (IR):** policies and procedures pertaining to incident response training, testing, handling, monitoring, reporting, and support services

- **Awareness and Training (AT):** policies and procedures to ensure that all information system users are given appropriate security training, relative to their use of the system, and that accurate training records are maintained

Technical Controls

Technical controls are characterized by implementation through software, hardware, or firmware elements. Based on NIST 800-53², NIST 800-82 defines the following technical controls:

- **Identification and Authentication (IA):** the process of verifying the identity of a user, process, or device through the use of specific credentials (e.g., passwords, tokens, biometrics) as a prerequisite for granting access to resources in an IACS
- **Access Control (AC):** the process of granting or denying specific requests for obtaining and using information and related information processing services for physical access to areas within the IACS environment

- **Audit and Accountability (AU):** independent review and examination of records and activities to assess the adequacy of system controls, to ensure compliance with established policies and operational procedures, and to recommend necessary changes in controls, policies, or procedures
- **System and Communications Protection (SC):** mechanisms for protecting both system and data transmission components

The application of these management, operational, and technical controls will serve to reduce the risk to industrial automation and control systems and will mitigate vulnerabilities. Another perspective, which reinforces the controls of NIST 800-82, includes the controls recommended by ANSI/ISA-TR99.00.01-2007.

ANSI/ISA-TR99.00.01-2007, Security Technologies for Industrial Automation and Control Systems

ANSI/ISA-TR99.00.01-2007³ provides information on a variety of cybersecurity technologies for industrial automation and control systems (IACS). This data can be used to mitigate risk and improve the security posture of industrial automation and control systems. The controls of ANSI/ISA-TR99.00.01-2007 are organized into the following categories:

- Authentication and Authorization Technologies
- Filtering/Blocking/Access Control Technologies
- Encryption Technologies and Data Validation
- Management, Audit, Measurement, Monitoring, and Detection Tools
- Industrial Automation and Control Systems Computer Software
- Physical Security Controls

Authentication and Authorization

ANSI/ISA-TR99.00.01-2007 describes authorization as “the initial step in protecting an IACS system and its critical assets from unwanted breaches. It is the process of determining who and what should be allowed into or out of a system.” Authentication is defined as “the process of positively identifying potential network users, hosts, applications, services, and resources, using a combination of identification factors or credentials. The result of this authentication process then becomes the basis for permitting or denying further actions.” In addition, authentication is further divided into the following two areas:

- **User Authentication** – Traditional computer authentication, such as “logging into a computer” or activating a human-machine interface (HMI) to adjust a process
- **Network Service Authentication** – The ability for networked devices to distinguish between authorized and unauthorized remote requests for IACS data or to perform actions on the IACS

The major components of authentication and authorization technologies spelled out in ANSI/ISA-TR99.00.01-2007 are summarized as follows:

- **Role-based Authorization** – Role-based access control (RBAC) uses roles, hierarchies, and constraints to organize user access levels and is attractive in situations where employees change positions frequently in an organization.
- **Password Authentication** – These technologies authenticate an individual, using a secret known by the user, such as a password or

PIN. ANSI/ISA-TR99.00.01-2007 points to an issue to be considered in a control environment where, “during a major crisis when human intervention is critically required, an operator may panic and have difficulty remembering the password and either be locked out completely or delayed in being able to respond to the event. If the password has been entered wrong and the system has a limit on allowed wrong password entries, the operator may be locked out permanently until an authorized employee can reset the account.”

- **Challenge/Response Authentication** – This authentication method uses a challenge/response, which requires a requestor and service provider both to share a secret. A challenge is sent to the service provider, and it answers with a unique, expected response.
- **Physical/Token Authentication** – The person requesting access uses a token or smart card, which might use multifactor authentication, to gain access to a system.

- **Biometric Authentication** – Biometric authentication uses the biological characteristics of an individual to confirm his or her identity. Characteristics include fingerprints, retina signatures, facial recognition, and signature dynamics.
- **Location-Based Authentication** – The authentication of a requestor is based on his or her physical location, as determined by a GPS or IP address.

Filtering/Blocking Access Control

This control uses filtering/blocking access control technologies, such as firewalls. A firewall provides for tracking successful and unsuccessful transmissions through the firewall, restricting data entering or leaving a network, and supporting interactions among networks. A firewall can filter by applications, ports, or IP addresses.

Specifically, ANSI/ISA-TR99.00.01-2007 states:

Firewalls enforce access control policies using mechanisms that either block or permit certain types of traffic, thus regulating the

flow of information. Firewalls typically block traffic from the outside of a protected area to the inside of a protected area, while permitting users on the inside to communicate with outside services. While it is important to have a firewall separating a company's enterprise network from the Internet, it is even more important to have firewalls between the enterprise network and industrial automation and control systems LANs.

The three primary types of firewalls are summarized as follows:

- Packet Filtering – Evaluates the address information in each packet of data relative to certain criteria and, as a result, can either drop the packet, forward the packet, or send a message to the originator. It looks at the data packet to get information about the source and destination addresses, the session's communications protocol (TCP, UDP, or ICMP), and the source and destination application port for the desired service. Because the processing of packets in this type of firewall requires a small amount of overhead, it has minimal impact on system performance.

- Stateful Inspection – Filters packets at the network layer, determines whether session packets are valid, and evaluates the packet at the application layer. A stateful inspection firewall uses an inspection engine to extract state-related information. This information includes packet sequence numbers, IP addresses, and ports engaged in the connection. It maintains this information in a dynamic state table and evaluates subsequent connection attempts. This type of firewall offers a high level of security, good performance, and transparency to end users, but is relatively expensive.
- Application Proxy – Is commonly a host computer that is running proxy server software, making it a proxy server. It operates by transferring a copy of each accepted data packet from one network to another, thereby masking the data's origin. A proxy server can control which services a workstation uses on the Internet, and it aids in protecting the network from outsiders who may be trying to get information about the network's design. This type of firewall is also

called an application layer gateway. It offers a high level of security but has a significant impact on network performance.

Encryption Technologies Data Validation

Symmetric and asymmetric encryption technologies (detailed in [Chapter 2](#)) are used to protect sensitive process-related information. Data validation technologies safeguard the accuracy and completeness of information used in the industrial process. As stated in ANSI/ISA-TR99.00.01-2007, “Symmetric key encryption can be used to distinguish communication by devices that are not part of the desired network. This feature is generally attractive for SCADA and other process control systems that wish to allow little or no access to the control network, but is difficult to deploy in systems requiring unrestricted Internet access.” Encryption can also be employed in a virtual private network (VPN), which provides for authentication, integrity, and protection from unauthorized disclosure. The most common VPN implementations are Internet Protocol Security (IPSec), Secure Shell (SSH), and Secure Sockets Layer (SSL).

Management, Audit, Measurement, Monitoring, and Detection

Audit and related mechanisms are used to evaluate the security posture of an industrial automation and control system, and forensic methods are used to detect and analyze incidents. Some of the events that can be tracked in typical audit and logging environments for automation systems are:

- Access to files, folders, or other resources
- Account logon events to automation system elements
- Changes to specific accounts
- Directory service accesses
- Instances of elevated privileges to specific users or accounts
- Process accesses
- Security policy modifications
- System events

Regarding management issues, ANSI/ISA-TR99.00.01-2007 discusses host configuration management (HCM) tools that systems administrators use to manage resources centrally, control access to systems, and set a general level of security for each host on a network. However, it notes that “industrial automation and control systems do not typically use HCM tools because of the policy-driven nature of the tools. Most of the configuration is done through the IACS application and is established because of functional needs rather than administrative or security policies.”

Other management aids, automated software management (ASM) tools, are applications used to distribute software across a network to specified hosts or groups of hosts. They are employed, to some degree, in IACS applications and are used to manage updates to antivirus and firewall software, for application version control, and for patch management.

Industrial Automation and Control Systems Computer Software

Automation and control system software might contain vulnerabilities due to programming errors and should be tested and evaluated to eliminate any such risk factors. ANSI/ISA-TR99.00.01-2007 identifies the three main types of software that have to be considered in industrial automation and control systems as server and workstation operating systems, real-time and embedded operating systems, and Web servers and Internet technologies. Many automation and control system hosts and HMI computers use the Windows, Unix, and Linux operating systems and are therefore vulnerable to attacks designed for these systems. Real-time devices and controllers, in many cases, use specific, vendor developed operating systems.

Physical Security Controls

These controls are defined by ANSI/ISA-TR99.00.01-2007 as “any physical measures, either active or passive, that limit physical access to any information assets in the IACS environment.” Physical security devices are designed to protect computer media assets and documents, physical equipment assets, personnel, and facilities. The three main categories of physical security control devices are:

- **Active** – Active devices are devices that can be engaged or disengaged as a function of policy, time, control algorithms, or other input. Typical examples are gates, locks, movable barriers, and doors.
- **Identification and Monitoring Devices** – These devices include various types of cameras, recording devices, sensors, and biometric devices. They usually require monitoring by a human to make security decisions.
- **Passive** – Passive devices are hard installations, such as concrete barriers, fences, and walls.

Personnel Security Controls

In ANSI/ISA-TR99.00.01-2007, personnel security falls under the category of physical security, and its elements are hiring policies, terms and conditions of employment, and related company policies and practices.

North American Electric Reliability Corporation, *Critical Infrastructure Protection Cybersecurity Standards*

The North American Electric Reliability Corporation (NERC) *Critical Infrastructure Protection (CIP) Cybersecurity Standards*⁴ (<http://www.nerc.com/page.php?cid=2|20>) are divided into Standards CIP-002-4 through CIP-009-4 and address “the identification and protection of critical cyber assets to support reliable operation of the Bulk Electric System (BES).” These eight standards will be reviewed in the following sections with the purpose of highlighting the important automation and control system security controls used in electricity generation and distribution systems. Even though these CIP standards were designed for the electric utility industry, the security principles listed are sound and applicable to the manufacturing and process industries. In particular, the following requirements, explained in detail in the following paragraphs, are particularly useful to enhancing the security of automation systems:

- CIP-002-4 - R1, R2
- CIP-003-4 - R4, R5, R6
- CIP-004-4 - R1, R2, R3
- CIP-005-4 - R1, R2, R3, R4, R5
- CIP-006-4 - R1, R2, R5
- CIP-007-4 - R1, R2, R3, R4, R8
- CIP-008-4 - R1
- CIP-009-4 - R1, R2

CIP-002-4 Cybersecurity – Critical Cyber Asset Identification

Standard CIP-002-4 requires the responsible entity to identify and document the critical cyber assets associated with the respective bulk electric system. The standard sets forth the following requirements for critical asset identification:

R1. Critical Asset Identification – The responsible entity shall develop a list of its identified critical assets determined through an annual application of the criteria contained in *CIP-002-4 Attachment 1 – Critical Asset Criteria*. The responsible entity shall update this list as necessary and review it at least annually. (Author note: Attachment 1 comprises items such as generating facilities, reactive power resources, blackstart resources, and transmission facilities.) The term blackstart refers to restarting a power system after all or part of the system has shut down. The restarting is implemented by isolated power stations being started individually and gradually being reconnected to each other in order to form an interconnected system again.

R2. Critical Cyber Asset Identification – Using the list of critical assets developed pursuant to Requirement R1, the responsible entity shall develop a list of associated critical cyber assets essential to the operation of the critical asset. The responsible entity shall update this list as necessary and review it at least annually.

For the purpose of Standard CIP-002-4, critical cyber assets are further qualified to be those having at least one of the following characteristics:

- The cyber asset uses a routable protocol to communicate outside the electronic security perimeter.
- The cyber asset uses a routable protocol within a control center.
- The cyber asset is dial-up accessible.

R3. Annual Approval – The senior manager or delegate(s) shall approve annually the list of critical assets and the list of critical cyber assets. Based on Requirements R1 and R2, the responsible entity may determine that it has no critical assets or critical cyber assets. The responsible entity shall keep a signed and dated record of the senior manager or delegate(s)'s approval of the list of critical assets and the list of critical cyber assets (even if such lists are null.)

Standard CIP-002-4 considers the following to be critical assets with numbering as in the standard:

1.1 Each group of generating units (including nuclear generation) at a single plant location with an aggregate highest rated net real power capability of the preceding 12 months equal to or exceeding 1500 MW in a single interconnection.

1.2. Each reactive resource or group of resources at a single location (excluding generation facilities) having aggregate net reactive power nameplate rating of 1000 mega volt Amperes Reactive (MVAR) or greater.

1.3. Each generation facility that the planning coordinator or transmission planner designates and informs the generator owner or generator operator as necessary to avoid Bulk Electric System (BES) adverse reliability impacts in the long-term planning horizon.

1.4. Each blackstart resource identified in the transmission operator's restoration plan.

1.5. The facilities comprising the cranking paths and meeting the initial switching requirements from the blackstart resource to the first interconnection point of the generation unit(s) to be started, or up to the point on the cranking path where two or more path options exist, as identified in the transmission operator's restoration plan. A cranking path is defined as a portion of the electric system that can be isolated and then energized to deliver electric power from a generation source to enable the startup of one or more other generating units.

1.6. Transmission facilities operated at 500 kV or higher.

1.7. Transmission facilities operated at 300 kV or higher at stations or substations interconnected at 300 kV or higher with three or more other transmission stations or substations.

1.8. Transmission facilities at a single station or substation location that are identified by the reliability coordinator, planning authority, or transmission planner as critical to the derivation of Interconnection Reliability Operating Limits (IROLs) and their associated contingencies.

1.9. Flexible AC Transmission Systems (FACTS), at a single station or substation location, that are identified by the reliability coordinator, planning authority, or transmission planner as critical to the derivation of Interconnection Reliability Operating Limits (IROLs) and their associated contingencies.

1.10. Transmission facilities providing the generation interconnection required to connect generator output to the transmission system that, if destroyed, degraded, misused, or otherwise rendered unavailable, would result in the loss of the assets identified by any generator owner as a result of its application of Attachment 1, criterion 1.1 or 1.3.

1.11. Transmission facilities identified as essential to meeting nuclear plant interface requirements.

1.12. Each special protection system (SPS), remedial action scheme (RAS) or automated switching system that operates BES Elements that, if destroyed, degraded, misused or otherwise rendered unavailable, would cause one or more Interconnection Reliability Operating Limits (IROLs) violations for failure to operate as designed.

1.13. Each system or facility that performs automatic load shedding, without human operator initiation, of 300 MW or more implementing under voltage load shedding (UVLS) or under frequency load shedding (UFLS) as required by the regional load shedding program.

1.14. Each control center or backup control center used to perform the functional obligations of the reliability coordinator.

1.15. Each control center or backup control center used to control generation at multiple plant locations, for any generation facility or group of generation facilities identified in criteria 1.1, 1.3, or 1.4. Each control center or backup control center used to control generation equal to or exceeding 1500 MW in a single interconnection.

1.16. Each control center or backup control center used to perform the functional obligations of the transmission operator that includes control of at least one asset identified in criteria 1.2, 1.5, 1.6, 1.7, 1.8, 1.9, 1.10, 1.11 or 1.12.

1.17. Each control center or backup control center used to perform the functional obligations of the balancing authority that includes at least one asset identified in criteria 1.1, 1.3, 1.4, or 1.13. Each control center or backup control center used to perform the functional obligations of the balancing authority for generation equal to or greater than an aggregate of 1500 MW in a single interconnection.

CIP-003-4 Cybersecurity – Security Management Controls

Standard CIP-003-4 requires that “Responsible Entities have minimum security management controls in place to protect critical cyber assets.” The specific requirements as given in CIP-003-004 are summarized as follows:

R1. Cybersecurity Policy – The responsible entity shall document and implement a cybersecurity policy that represents management’s commitment and ability to secure its critical cyber assets.

R2. Leadership – The responsible entity shall assign a single senior manager with overall responsibility and authority for leading and managing the entity’s implementation of, and adherence to, standards CIP-002-4 through CIP-009-4.

R3. Exceptions – Instances where the responsible entity cannot conform to its cybersecurity policy must be documented as exceptions and authorized by the senior manager or delegate(s).

R4. Information Protection – The responsible entity shall implement and document a program to identify, classify, and protect information associated with critical cyber assets.

R5. Access Control – The responsible entity shall document and implement a program for managing access to protected critical cyber asset information.

R6. Change Control and Configuration Management – The responsible entity shall establish and document a process of change control and configuration management for adding, modifying, replacing, or removing critical cyber asset hardware or software and implement supporting configuration management activities to identify, control, and document all entity or vendor-related changes to hardware and software components of critical cyber assets pursuant to the change control process.

CIP-004-4 Cybersecurity – Personnel & Training

Standard CIP-004-4 requires that “personnel having authorized cyber or authorized unescorted physical access to critical cyber assets, including contractors and service vendors, have an appropriate level of personnel risk assessment, training, and security awareness.”

The requirements of CIP-004-4 are:

R1. Awareness – The responsible entity shall establish, document, implement, and maintain a security awareness program to ensure personnel having authorized cyber or authorized unescorted physical access to critical cyber assets receive ongoing reinforcement in sound security practices. The program shall include security awareness reinforcement on at least a quarterly basis using mechanisms such as:

- Direct communications (e.g., emails, memos, computer-based training)
- Indirect communications (e.g., posters, intranet, brochures)
- Management support and reinforcement (e.g., presentations, meetings)

R2. Training – The responsible entity shall establish, document, implement, and maintain an annual cybersecurity training program for personnel having authorized cyber or authorized unescorted physical access to critical cyber assets. The cybersecurity training program shall be reviewed annually, at a minimum, and shall be updated whenever necessary.

R3. Personnel Risk Assessment – The responsible entity shall have a documented personnel risk assessment program, in accordance with federal, state, provincial, and local laws, and subject to existing collective bargaining unit agreements, for personnel having authorized cyber or authorized unescorted physical access to critical cyber assets. A personnel risk assessment shall be conducted pursuant to that program, prior to such personnel being granted such access, except in specified circumstances, such as an emergency.

R4. Access – The responsible entity shall maintain list(s) of personnel with authorized cyber or authorized unescorted physical access to

critical cyber assets, including their specific electronic and physical access rights to critical cyber assets.

CIP-005-4 Cybersecurity – Electronic Security Perimeter(s)

Standard CIP-005-4 addresses “the identification and protection of the electronic security perimeter(s) inside which all critical cyber assets reside, as well as all access points on the perimeter.” The requirements for this standard are summarized as follows:

R1. Electronic Security Perimeter – The responsible entity shall ensure that every critical cyber asset resides within an electronic security perimeter. The responsible entity shall identify and document the electronic security perimeter(s) and all access points to the perimeter(s).

R2. Electronic Access Controls – The responsible entity shall implement and document the organizational processes and technical and procedural mechanisms for control of electronic access at all electronic access points to the electronic security perimeter(s).

R3. Monitoring Electronic Access – The responsible entity shall implement and document an electronic or manual process(es) for monitoring and logging access at access points to the electronic security perimeter(s) twenty-four hours a day, seven days a week.

R4. Cyber Vulnerability Assessment – The responsible entity shall perform a cyber vulnerability assessment of the electronic access points to the electronic security perimeter(s) at least annually.

R5. Documentation Review and Maintenance – The responsible entity shall review, update, and maintain all documentation to support compliance with the requirements of Standard CIP-005-4.

CIP-006-4 Cybersecurity – Physical Security of Critical Cyber Assets

The CIP-006-4 standard “is intended to ensure the implementation of a physical security program for the protection of critical cyber assets.” A summary of the requirements of this standard is given as follows:

R1. Physical Security Plan – The responsible entity shall document, implement, and maintain a physical security plan, approved by the senior manager or delegate(s) that shall address, at a minimum, the following:

R1.1. All cyber assets within an electronic security perimeter shall reside within an identified physical security perimeter. Where a completely enclosed (“six-wall”) border cannot be established, the responsible entity shall deploy and document alternative measures to control physical access to such cyber assets.

R1.2. Identification of all physical access points through each physical security perimeter and measures to control entry at those access points.

R1.3. Processes, tools, and procedures to monitor physical access to the perimeter(s).

R1.4. Appropriate use of physical access controls as described in Requirement R4, including visitor pass management, response to loss, and prohibition of inappropriate use of physical access controls.

R1.5. Review of access authorization requests and revocation of access authorization, in accordance with CIP-004-4 Requirement R4.

R1.6. A visitor control program for visitors (personnel without authorized unescorted access to a physical security perimeter), containing at a minimum the following:

R1.6.1. Logs (manual or automated) to document the entry and exit of visitors, including the date and time, to and from physical security perimeters.

R1.6.2. Continuous escorted access of visitors within the physical security perimeter.

R1.7. Update of the physical security plan within thirty calendar days of the completion of any physical security system redesign or reconfiguration, including, but not limited to, addition or removal of access points through the physical security perimeter, physical access controls, monitoring controls, or logging controls.

R1.8. Annual review of the physical security plan.

R2. Protection of Physical Access Control Systems – cyber assets that authorize and/or log access to the physical security perimeter(s), exclusive of hardware at the physical security perimeter access point, such as electronic lock control mechanisms and badge readers, shall:

R2.1. Be protected from unauthorized physical access.

R2.2. Be afforded the protective measures specified in Standard CIP-003-4; Standard CIP-004-4 Requirement R3; Standard CIP-005-4 Requirements R2 and R3; Standard CIP-006-4 Requirements R4 and R5; Standard CIP-007-4; Standard CIP-008-4; and Standard CIP-009-4.

R3. Protection of Electronic Access Control Systems – cyber assets used in the access control and/or monitoring of the electronic security perimeter(s) shall reside within an identified physical security perimeter.

R4. Physical Access Controls – The responsible entity shall document and implement the operational and procedural controls to manage physical access at all access points to the physical security perimeter(s) twenty-four hours a day, seven days a week.

R5. Monitoring Physical Access – The responsible entity shall document and implement the technical and procedural controls for monitoring physical access at all access points to the physical security perimeter(s) twenty-four hours a day, seven days a week. Unauthorized

access attempts shall be reviewed immediately and handled in accordance with the procedures specified in Requirement CIP-008-4.

R6. Logging Physical Access – Logging shall record sufficient information to uniquely identify individuals and the time of access twenty-four hours a day, seven days a week. The responsible entity shall implement and document the technical and procedural mechanisms for logging physical entry at all access points to the physical security perimeter(s).

R7. Access Log Retention – The responsible entity shall retain physical access logs for at least ninety calendar days. Logs related to reportable incidents shall be kept in accordance with the requirements of Standard CIP-008-4.

R8. Maintenance and Testing – The responsible entity shall implement a maintenance and testing program to ensure that all physical security systems under Requirements R4, R5, and R6 function properly.

CIP-009-4 Cybersecurity – Recovery Plans for Critical Cyber Assets

Standard CIP-009-4 “ensures that recovery plan(s) are put in place for critical cyber assets and that these plans follow established business continuity and disaster recovery techniques and practices.” The corresponding requirements are:

R1. Recovery Plans – The responsible entity shall create and annually review recovery plan(s) for critical cyber assets. The recovery plan(s) shall address at a minimum the following:

R1.1. Specify the required actions in response to events or conditions of varying duration and severity that would activate the recovery plan(s).

R1.2. Define the roles and responsibilities of responders.

R2. Exercises – The recovery plan(s) shall be exercised at least annually. An exercise of the recovery plan(s) can range from a paper drill, to a full operational exercise, to recovery from an actual incident.

R3. Change Control – The recovery plan(s) shall be updated to reflect any changes or lessons learned as a result of an exercise or the recovery from an actual incident. Updates shall be communicated to personnel responsible for the activation and implementation of the recovery plan(s) within thirty calendar days of the change being completed.

R4. Backup and Restore – The recovery plan(s) shall include processes and procedures for the backup and storage of information required to successfully restore critical cyber assets. For example, backups may include spare electronic components or equipment, written documentation of configuration settings, tape backup.

R5. Testing Backup Media – Information essential to recovery that is stored on backup media shall be tested at least annually to ensure that the information is available. Testing can be completed off site.

Summary

Chapter 6 presents the most popular and effective controls designed to secure industrial automation and control systems specifically or which could be adapted to such systems. These standards and guidelines form a comprehensive, structured methodology for protecting manufacturing facilities, process plants, and the critical infrastructure. A useful output of this chapter is the consolidation of these best practices to provide a single reference source as a baseline for securing industrial automation and control systems.